ANALISIS Y PLANIFICACION DEL PENTEST (ACTIVIDAD 1)

Dana Paola Martínez Hernández

HACKER WOMEN COUNCIL – ETHICAL HACKING

INDICE

HISTORIAL DE VERSIONES 1
OBJETIVOS DEL PENTEST 2
ALCANCE 2
AUTORIZACIÓN Y CONDICIONES 2
TIPO DE PENTEST.....3
PLANIFICACION.....3
FASES DEL PENTES 4
INVESTIGACIÓN 4

HISTORIAL DE VERSIONES

NUMERO DE VERSION	NOMBRE	FECHA	DESCRIPCION DE LOS CAMBIOS
1.0	Dana Paola Martínez Hernández	03/09/2026	Documento creado

OBJETIVOS DEL PENTEST

- Evaluar los mecanismos de inicio de sesión y control de acceso para identificar fallas que permitan a un usuario ver la información privada de otra cuenta.
- Detectar vulnerabilidades en la entrada de datos (como inyección SQL o XSS) que puedan comprometer la base de datos o la integridad del sitio web.
- Verificar que los paneles de administración y funciones de altos privilegios cuenten con un control de acceso riguroso, que impida a usuarios no autorizados gestionar productos o datos globales

ALCANCE

- SE EVALUARÁ

1. La plataforma web principal de Aurora Market (proceso de inicio de sesión, registro y perfiles de usuario).
2. El módulo de compras (mecanismos del carrito, catálogo de productos y consulta de pedidos).
3. El panel de administración web (interfaz para gestionar productos, usuarios y pedidos).
4. Los formularios e insumos de datos que se conectan con la base de datos de la app.

- NO SE EVALUARÁ

1. Redes sociales de la empresa o de los empleados.
2. Equipos personales (laptops, celulares) y cuentas de correo del personal.
3. Proveedores externos y sistemas de terceros que no forman parte del alcance acordado.
4. Cualquier acción que interrumpa deliberadamente el funcionamiento de la plataforma o altere/elimine información real de los clientes.

AUTORIZACIÓN Y CONDICIONES

- PERMISOS REQUERIDOS:

    1. Se solicitará un contrato formal y la carta de autorización firmada por Aurora Market para validar legalmente las pruebas y delimitar el alcance.
    2. Se requerirá el acceso a credenciales de prueba con diferentes niveles de privilegio para evaluar tanto a usuarios normales como a administradores.
    3. Se mantendrá una vía de comunicación directa con un contacto técnico de la empresa para reportar inmediatamente cualquier hallazgo crítico.

- CONDICIONES ACORDADAS:

    1. Las evaluaciones se realizarán principalmente en horarios nocturnos o de bajo tráfico para no interrumpir la experiencia de las personas que estén comprando.
    2. Se mantendrá un respeto estricto del alcance limitándonos solo a la aplicación web, evitando involucrar al personal o sus correos corporativos.
    3. Se ejecutarán únicamente pruebas no destructivas para no alterar la base de datos real ni tumbar el sitio web.

TIPO DE PENTEST

- CAJA GRIS (Gray-Box):

- Se selecciona esta modalidad debido a que se cuenta con información parcial del sistema, como la estructura general de la aplicación web y el acceso a credenciales de prueba con diferentes niveles de privilegio.
- Permite simular el comportamiento de un atacante que posee cierto conocimiento previo o de un usuario autenticado que intenta elevar sus accesos, sin necesidad de tener el código fuente completo ni los diagramas internos de la infraestructura.

PLANIFICACION

- **OBJETIVOS:** Evaluar autenticación, probar entrada de datos (SQLi/XSS) y verificar el control de acceso del panel administrativo.
- **ALCANCE:** Evaluar únicamente la plataforma web de Aurora Market (login, compras, panel admin), dejando fuera a los empleados y evitando cualquier acción que interrumpa el funcionamiento de la plataforma o altere/elimine información de los clientes.
- **PERMISOS Y CONDICIONES:** Carta de autorización firmada, credenciales de prueba por roles y ejecuciones nocturnas de bajo tráfico.
- **METODOLOGÍA A UTILIZAR**: OWASP.
- **RECOPILACIÓN DE INFORMACIÓN PREVIA:** Revisión de la arquitectura conocida (sitio web, base de datos) y análisis del tipo de Pentest (Caja Gris).
- **RECURSOS NECESARIOS:** Herramientas de análisis web, credenciales de prueba y un contacto técnico de emergencia.
- **PROGRAMACIÓN DEL PENTEST:** Definición de fechas de inicio/fin y horarios nocturnos para ejecutar los escaneos sin impactar el servicio.

FASES DEL PENTEST

1. **RECONOCIMIENTO:** Mapear la aplicación web de Aurora Market, identificando URL, formularios de registro, login y secciones del panel de administración.
2. **ANÁLISIS DE VULNERABILIDADES:** Buscar fallas en la validación de formularios (como inyección SQL) y errores en la gestión de sesiones de usuario.
3. **EXPLOTACIÓN:** Probar de forma segura si es posible acceder a datos de otros usuarios o elevar privilegios al panel de administración sin autorización.
4. **POST-EXPLOTACIÓN**: Determinar el alcance del impacto (por ejemplo, si se podría modificar la base de datos o consultar información sensible) sin alterar el sitio real.
5. **INFORME:** Documentar todas las vulnerabilidades encontradas, su nivel de riesgo y las recomendaciones técnicas para que Aurora Market las solucione.

INVESTIGACIÓN

- METODOLIGIA ELEGIDA**:**

    - OWASP: Se elige esta metodología estandarizada por ser la referencia internacional más reconocida para evaluar la seguridad en aplicaciones web y comercio electrónico.

- ¿POR QUE SERIA UTIL PARA ESTE PROYECTO?:

    - Organización para el auditor: Permite saber exactamente por dónde empezar y qué fallas específicas buscar (como inyecciones SQL o errores de autenticación), evitando revisiones al azar o perder tiempo en áreas secundarias.
    - Confiabilidad para la empresa: Al seguir un protocolo avalado a nivel mundial, Aurora Market tiene la garantía de que la evaluación es rigurosa, profesional y cubre los riesgos reales.
    - Lenguaje técnico universal: Genera un reporte claro que cualquier equipo de desarrollo o ciberseguridad posterior podrá entender y aplicar fácilmente para corregir las vulnerabilidades.